

A.H

Política de Detección y Notificación de Incidentes

1. INTRODUCCIÓN

Esta Política de Detección y Notificación de Incidentes tiene como objetivo establecer un marco sencillo pero eficaz para identificar y comunicar los incidentes de seguridad que puedan afectar a la organización. Este documento está inspirado en las directrices oficiales publicadas por el Instituto Nacional de Ciberseguridad (INCIBE) en su Guía Nacional de Notificación y Gestión de Ciberincidentes, así como en las políticas recogidas en el Esquema Nacional de Seguridad (ENS), el Reglamento General de Protección de Datos (RGPD) y las guías del CCN-CERT para la gestión de incidentes.

2. ALCANCE

Esta política se debe aplicar a todos los empleados, colaboradores y proveedores que utilicen los recursos tecnológicos de la organización. Incluye los sistemas informáticos, redes, aplicaciones, servicios en la nube y cualquier otro medio digital que pueda verse afectado por un incidente de seguridad. También abarca los incidentes que, por su gravedad o impacto, deban notificarse a organismos oficiales como INCIBE-CERT, CCN-CERT o CNPIC, siguiendo la legislación española vigente.

3. DEFINICIONES BÁSICAS

- Incidente de seguridad: Cualquier evento que ponga en riesgo la confidencialidad, integridad o disponibilidad de la información (la tríada CIA).
- Detección: Proceso de identificación de un posible incidente por parte de una persona o sistema automatizado.
- Notificación: Comunicación formal de un incidente detectado a los responsables internos o, si procede, a un CSIRT oficial.
- CSIRT: Equipo de Respuesta ante Incidentes de Seguridad Informática. En España destacan INCIBE-CERT (ámbito privado) y CCN-CERT (ámbito público).

- Nivel de peligrosidad e impacto: Clasificación del incidente según la Guía INCIBE en los niveles Crítico, Muy Alto, Alto, Medio y Bajo.

4. OBJETIVOS DE LA POLÍTICA

El objetivo principal es garantizar que todos los incidentes sean detectados y comunicados de forma rápida, clara y trazable. Además, busca reducir el impacto de los incidentes mediante una respuesta coordinada y conforme a la legislación española.

Entre los objetivos específicos destacan:

- Establecer un proceso de notificación.
- Cumplir con los requisitos de comunicación a los CSIRT nacionales.
- Proteger la información y evitar la pérdida de datos.
- Fomentar la cultura de ciberseguridad dentro de la organización, mediante cursos y formaciones.

5. ROLES Y RESPONSABILIDADES

Cada persona dentro de la organización tiene un papel clave en la detección y notificación de incidentes:

- Todo empleado: debe informar inmediatamente al detectar un incidente o anomalía.
- Departamento de IT o Seguridad: verifica la validez del incidente y coordinar la respuesta.
- Responsable de Seguridad o CSIRT interno: evalúa la gravedad, clasifica el incidente y decide si es necesario notificarlo externamente.
- Delegado de Protección de Datos (DPO): interviene si hay datos personales comprometidos.
- Dirección: aprueba las acciones de respuesta y la comunicación pública, si fuera necesaria.

6. PROCEDIMIENTO DE DETECCIÓN Y NOTIFICACIÓN

El procedimiento se divide en varias fases, adaptadas de la Guía Nacional de Notificación y Gestión de Ciberincidentes del INCIBE:

1. Detección del incidente: Puede provenir de un usuario, sistema de monitorización o aviso de terceros.
2. Registro: El empleado o sistema debe registrar el incidente con la mayor cantidad de información posible: fecha, descripción, equipo afectado, acciones realizadas y evidencia disponible.
3. Notificación interna: El incidente debe comunicarse por los canales establecidos (correo interno de seguridad o sistema de tickets como Jira o Zendesk).
4. Clasificación: El responsable de seguridad valora la gravedad y el impacto siguiendo la clasificación de la Guía INCIBE.
5. Notificación externa: Si el incidente es grave (nivel Alto, Muy Alto o Crítico), debe notificarse al CSIRT de referencia en un plazo máximo de 24 horas (inmediato en casos críticos), incluyendo los datos mínimos exigidos por la Guía.
6. Seguimiento y cierre: Se documentan las acciones tomadas, los resultados y se archiva el caso con su estado final (resuelto, falso positivo, etc.).

7. CANALES DE NOTIFICACIÓN

- Correo electrónico de seguridad: seguridad@[empresa].com
- Sistema interno de tickets: categoría 'Incidente de seguridad'.
- Línea telefónica de emergencia interna.
- CSIRT de referencia (INCIBE-CERT, CCN-CERT, CNPIC) para casos graves.

8. TIEMPOS DE RESPUESTA Y NOTIFICACIÓN

Según la Guía INCIBE, los plazos de notificación para incidentes graves son:

- Crítico: Notificación inmediata (menos de 1 hora) y Intermedia 24/48 horas y final 20 días.
- Muy Alto: Notificación Inicial inmediata Intermedia en 72 horas final en 40 días.
- Alto: Inicial inmediata.

En el cuadro proporcionado por INCIBE no se muestran más datos, supongo que, al bajar el nivel de criticidad, las empresas establecen sus propios tiempos de notificación.

Nivel de peligrosidad o impacto	Notificación inicial	Notificación intermedia	Notificación final
CRÍTICO	Inmediata	24 / 48 horas	20 días
MUY ALTO	Inmediata	72 horas	40 días
ALTO	Inmediata	-	-
MEDIO	-	-	-
BAJO	-	-	-

Estos plazos pueden ajustarse internamente, pero siempre respetando la legislación española y las recomendaciones del INCIBE.

9. CONFIDENCIALIDAD Y FORMACIÓN

Toda la información relacionada con los incidentes es confidencial. Solo el personal autorizado puede acceder a ella. Se recomienda que todos los empleados reciban formación anual sobre detección, reporte y gestión de incidentes de seguridad.

10. REVISIÓN Y MEJORA CONTINUA

Esta política se revisará al menos una vez al año o después de un incidente relevante. Se fomentará la mejora continua mediante la evaluación de los tiempos de respuesta, la calidad de los reportes y las lecciones aprendidas.

11. FUENTES Y REFERENCIAS

- Instituto Nacional de Ciberseguridad (INCIBE): Guía Nacional de Notificación y Gestión de Ciberincidentes (2021).
- Esquema Nacional de Seguridad (ENS) – Ministerio de Asuntos Económicos y Transformación Digital.
- Real Decreto-ley 12/2018, de seguridad de las redes y sistemas de información.
- Reglamento General de Protección de Datos (UE) 2016/679 (RGPD).
- CCN-CERT: Guías de gestión y respuesta ante incidentes (Centro Criptológico Nacional).

